PRAVEEN V 241901082

Exercise 15
Detect SQL Injection Vulnerabilities Using Various SQL Injection Detection Tools

AIM

To detect SQL injection vulnerabilities in a target web application using various detection tools such as SQLMap, OWASP ZAP and Burp Suite, and to compare the results obtained from each tool.

PROCEDURE

a) Detection Using SQLMap

1. Open a terminal in Kali Linux.
2. Identify a URL parameter in the target application that interacts with the database (e.g., product ID, login field).
3. Run SQLMap against the parameter to test for injectability: sqlmap -u "http://testphp.vulnweb.com/listproducts.php?cat=1" --batch
4. Note whether the parameter is reported as vulnerable, along with the injection type (boolean-based, error-based, UNION-based, time-based) and backend DBMS identified.

b) Detection Using OWASP ZAP

1. Open OWASP ZAP and set the browser proxy to route through it (127.0.0.1:8080).
2. Load the target site through the proxy so it is added to the Sites tab.
3. Right-click the target site and select Attack → Active Scan, then start the scan.

4. Open the Alerts tab and check for any SQL Injection alerts reported, along with their risk level.

c) Detection Using Burp Suite

1. Open Burp Suite and route browser traffic through its proxy with Intercept on.
2. Browse the application to populate the Site Map, then send a request with a database parameter to Repeater.
3. Manually test the parameter with payloads such as ', ' OR '1'='1, ' AND SLEEP(5)-- and observe the response (error message, content change, or time delay).
4. Note whether the parameter shows signs of SQL injection based on the response behavior.

d) Comparing the Results

1. Tabulate the findings from SQLMap, OWASP ZAP and Burp Suite.
2. Note which tool(s) detected the vulnerability, the confidence/accuracy of detection, and any false negatives.

PRAVEEN V 241901082

OBSERVATION TABLE

S.No	Tool Used	Parameter Tested	Vulnerability Detected	Injection Type	Remarks
1	SQLMap	cat (GET)	Yes	Boolean-based blind	Backend DBMS: MySQL
2	OWASP ZAP	cat (GET)	Yes	SQL Injection (ZAP alert)	Risk: High
3	Burp Suite	cat (GET)	Yes	Error/time-based (manual)	Confirmed using SLEEP payload
4	SQLMap	artist (GET)	No	-	Not injectable

OUTPUT

SQLMap output:

Parameter: cat (GET)

Type: boolean-based blind

Title: AND boolean-based blind - WHERE or HAVING clause

back-end DBMS: MySQL >= 5.0

OWASP ZAP Alert:

Risk: High

Alert: SQL Injection

URL: http://testphp.vulnweb.com/listproducts.php?cat=1

Parameter: cat

Burp Suite manual test (time-based):

Request: GET /listproducts.php?cat=1' AND SLEEP(5)--

Response time: 5.2 seconds (confirms injection)

Comparison result:

Detected by all three tools: cat parameter

Fastest/most detailed: SQLMap (DBMS and injection type identified)

Confirmed manually: Burp Suite (time-based response delay)

RESULT

Thus, SQL injection vulnerabilities in the target web application were successfully detected using SQLMap, OWASP ZAP and Burp Suite. The results from each tool were compared, confirming the vulnerable parameter through multiple detection methods.